

Section 10

Industrial Security (Bachelor)



Section 10 – Incident Response and Recovery

Incident Response and Recovery

Lecture Notes

Department of Computer Science

1 OT-Specific Considerations

2 Forensics and Reporting

3 Exercises and Continuity

By the end of this section you will be able to

- Distinguish IT and OT considerations in incident response.
- Build a basic OT IR playbook.
- Understand forensic acquisition options on ICS devices.
- Plan a tabletop exercise.

1

OT-Specific Considerations

Section 10 – Incident Response and Recovery

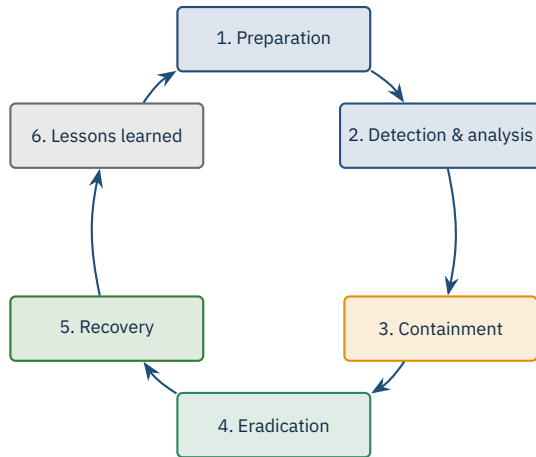
Safety first – a wrong response may cause a worse incident

Don't pull the cable – losing visibility can blind operators

Process owners must be in the IR loop, not just IT

Some forensic actions (memory dump on running PLC) are infeasible

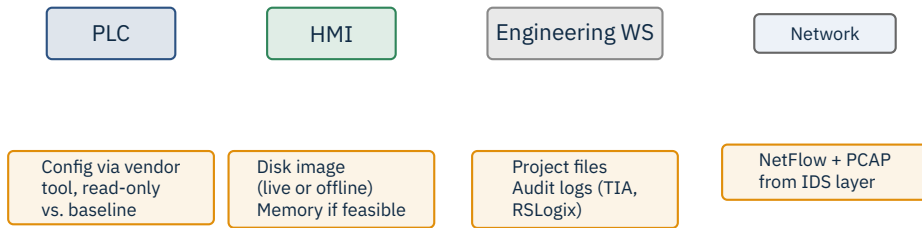
Containment may require manual fall-back to local control



2

Forensics and Reporting

Section 10 – Incident Response and Recovery



Chain of custody from minute one.



Also: national CERT (BSI / CISA), sector ISAC (E-ISAC, WaterISAC), law enforcement, regulators, customers per contract.

Source: Directive (EU) 2022/2555 (NIS2), Art. 23: 24h early warning, 72h notification, 1-month final report.

3

Exercises and Continuity

Section 10 – Incident Response and Recovery

Ransomware encrypts the Historian

Insider exfiltrates PLC programs before resignation

Nation-state intrusion into Safety Instrumented System

Vendor remote-access account is compromised

Suspicious unsolicited Modbus writes from IT subnet



Rehearse

Plans must be rehearsed. Paper plans fail under stress.

Activity	Operator	Control Eng	OT Security	Plant Mgr
Detect anomaly	R	C	I	I
Assess process risk	C	R	C	A
Contain (segment FW)	I	C	R	A
Stop production	C	C	C	A/R
Forensic capture	I	C	R	I
External notification	I	I	C	A

R = Responsible, A = Accountable, C = Consulted, I = Informed.

Wireshark / tshark

Zeek

Suricata + ICS rules

Malcolm (full stack)

NetworkMiner

tcpdump

Workflow

PCAP first, parse second, derive metrics third. Never reformat raw evidence – keep an immutable copy and work on a derivative.

- **Internal first:** plant operator, on-call engineer, executive sponsor.
- **External next:** CERT (BSI / CISA), sectoral ISAC, regulators.
- Templates for each audience: technical (engineering), operational (plant managers), executive (board), public (PR).
- Use a **single channel of truth** – e.g. war-room chat – to avoid contradictory updates.

Caution

Speculation kills credibility. Communicate *what you know* and *what you do not know* separately.

1. Timeline of events with timestamps

2. What happened (root cause, contributing factors)

3. What worked / what did not

4. Action items with owners and due dates

5. Follow-up review date

Blameless

Focus on systems and decisions, never on individuals.



Cadence depends on regulatory pressure (NERC CIP, KRITIS) and on the maturity of the team.

- Verify integrity of restored PLC programs against a signed baseline.
- Re-baseline alarms and trends – known-good snapshot before declaring “done”.
- Heightened monitoring window (e.g. 72 hours) after recovery.
- Capture lessons learned within 5 working days while details are fresh.

Don't rush

Premature “all clear” is how secondary incidents happen. The attacker may still be present.

★ Key Takeaway: What to remember from this section

- OT IR rules differ from IT IR – safety leads, visibility matters more than isolation.
- Forensics on PLCs is constrained; the network capture is the most valuable evidence.
- Regulators expect short reporting windows – 24 / 72 hours under NIS2.
- Tabletops surface gaps before incidents do; rehearse recovery, not just plans.

End of Section 10

Incident Response and Recovery

Questions and discussion